Tehnologii Web

securitatea aplicațiilor Web

aspecte esențiale

Username : admin
Password : admin

reddit.com/r/ProgrammerHumor

Dr. Sabin Corneliu Buraga – profs.info.uaic.ro/~busaco/

„Experiența este acel minunat lucru care îți dă voie să recunoști o greșeală pe care ai mai făcut-o.”

F.P. Jones

Ce înseamnă securitatea datelor?

securitatea datelor

Securitatea este procesul de **menținere** a unui nivel acceptabil de risc perceptibil

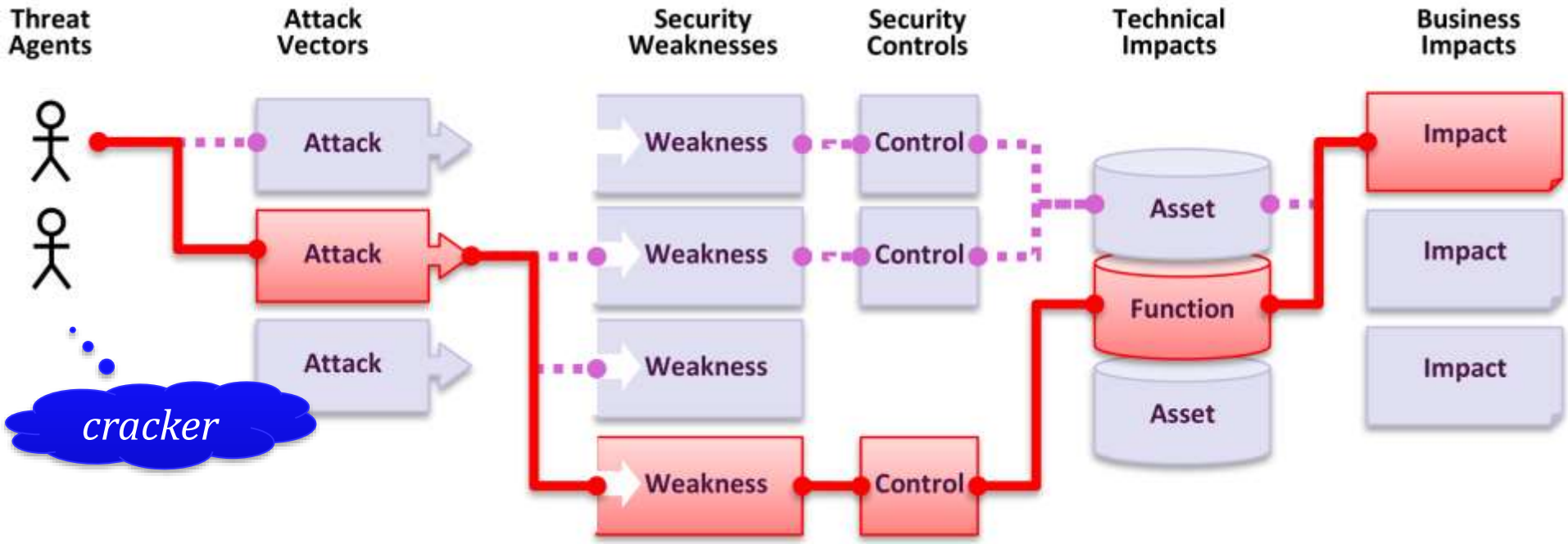
securitatea datelor

Securitatea este procesul de **menținere** a unui nivel acceptabil de risc perceptibil

"*Security is a process, not an end state.*"
Mitch Kabay

An Introduction to Information Security (NIST, 2017)
www.nist.gov/publications/introduction-information-security

securitatea datelor



riscuri de securitate (*Web application security risks*)
conform OWASP – *Open Web Application Security Project*
www.owasp.org

securitatea datelor: aspecte esențiale

Confidențialitatea
Autentificarea
Autorizarea
Integritatea
Nerepudierea
Intimitatea (*privacy*)
Disponibilitatea

securitatea datelor

Confidențialitatea

imposibilitatea unei terțe entități să aibă acces la datele vehiculate între doi receptori

securitatea datelor

Confidențialitatea

soluție:

conexiuni private între cele 2 puncte terminale
ale canalului de comunicație

datele circulă printr-un tunel oferit de o rețea privată
virtuală (VPN – *Virtual Private Network*)

securitatea datelor

Confidențialitatea

la nivel de Web:
tunneling via proxy
developer.mozilla.org/Web/HTTP/Proxy_servers_and_tunneling

DoH (*DNS over HTTPS*) – propus de Mozilla
previne modificarea datelor DNS solicitate de *browser*
pentru a rezolva adresa IP asociată domeniului din URL
vezi și **dnsprivacy.org/wiki/**
JSON API – **developers.google.com/speed/public-dns/docs/doh/json**

securitatea datelor

Confidențialitatea

HTTPS (*HyperText Transfer Protocol Secure*)

scop: criptare bidirecțională + autentificare „sigură”, prevenind atacuri de tip *man-in-the-middle* și interceptare/alterare de date (*eavesdropping*, *tampering*)

RFC 7230

securitatea datelor

Confidențialitatea

HTTPS (*HyperText Transfer Protocol Secure*)

HTTP over TLS (*Transport Layer Security*)

URL-urile folosesc schema **https** – port standard: **443**

studiu de caz: *HTTPS on Stack Overflow* (2017)
nickcraver.com/blog/2017/05/22/https-on-stack-overflow/

securitatea datelor

Confidențialitatea

soluție:

criptarea datelor via diverse abordări (algoritmi)
tutoriale practice: **www.crypto101.io** • **cryptohack.org**

specificația generală: Web Cryptography API
(recomandare a Consorțiului Web, 2017)
www.w3.org/TR/WebCryptoAPI/

avansat

securitatea datelor

Exemplificări de soluții criptografice – biblioteci specializate și/sau oferite de mediile de dezvoltare Web:

OpenSSL (bibliotecă C; numeroase portări) – **openssl.org**
Java Cryptography Architecture
Forge (JavaScript) – **github.com/digitalbazaar/forge**
System.Security.Cryptography (.NET)
crypto (Node.js) – **www.npmjs.com/package/crypto-js**
laminas-crypt, Mcrypt, phpseclib,... (PHP)
Cryptography Toolkit (Python) – **www.pycrypto.org**

mai multe la **github.com/sobolevn/awesome-cryptography**

securitatea datelor

Autentificarea

permite utilizatorilor să acceseze
un serviciu după verificarea identității
utilizatorului – uzual, pe bază de nume + parolă

securitatea datelor

Autentificarea

soluție:

serverul Web oferă suport pentru
autentificări de bază (*basic authentication*)
sau bazate pe algoritmi de tip *digest* (*hash*)
– *e.g.*, SHA-2 (SHA-256, SHA-512 etc.), SHA-3
csrc.nist.gov/projects/hash-functions

avansat

securitatea datelor

Autentificarea

exemplificări:
mod_auth_basic, mod_auth_digest, mod_authn_dbd,...
(module Apache)
httpd.apache.org/docs/howto/auth.html

ngx_http_auth_basic_module, ngx_http_auth_request_module
(module Nginx)
pentru alte soluții, de vizitat **wiki.nginx.org/Modules**

avansat

securitatea datelor

Autentificarea

soluție:

folosirea/implementarea unor servicii de autentificare
de exemplu, OpenID Connect (pe baza OAuth2)

vezi unul dintre
cursurile anterioare

pentru utilizatori umani, de recurs la autentificare
multi-factor – *e.g.*, *Two Factor Auth* (2FA)

securitatea datelor

Autorizarea

specifică acțiunile (rolurile) pe care un utilizator
ori o aplicație a utilizatorului
le poate realiza într-un anumit context

securitatea datelor

Autorizarea

specifică acțiunile (rolurile) pe care un utilizator
ori o aplicație a utilizatorului
le poate realiza într-un anumit context

asociată autentificării

permite definirea politicilor de control al accesului
la servicii (funcționalități)

securitatea datelor

Autorizarea

soluții:

drepturi de acces (permisiuni)
+
liste de control al accesului (ACL – *Access Control List*)

context: autorizarea accesului la datele disponibile
în cadrul unei aplicații Web – *e.g.*, via OAuth

securitatea datelor

Autorizarea

soluții:

controlul accesului bazat pe roluri
(RBAC – *Role-Based Access Control*)

exemplu:
un utilizator obișnuit cu rol de administrator
într-o situație specifică

securitatea datelor

Integritatea

în acest context, implică detectarea încercărilor de modificare neautorizată (*tampering*) a datelor transmise

securitatea datelor

Integritatea

soluții:

CRC (*Cyclic Redundancy Check*)

algoritmi de tip *digest*

sume de control – (*cryptographic*) *checksums*

securitatea datelor

Nerepudierea

asigură faptul că expeditorul unui mesaj nu poate afirma că nu l-a trimis

securitatea datelor

Nerepudierea

soluție:

semnături digitale

certificate digitale

semnături digitale recunoscute de o terță parte care confirmă că semnatura aparține acelei entități

securitatea datelor

PKI (*Public Key Infrastructure*)
infrastructura bazată de chei publice

set de resurse hardware, software, umane + politici și proceduri pentru managementul certificatelor digitale (creare, distribuție, utilizare, stocare, revocare)

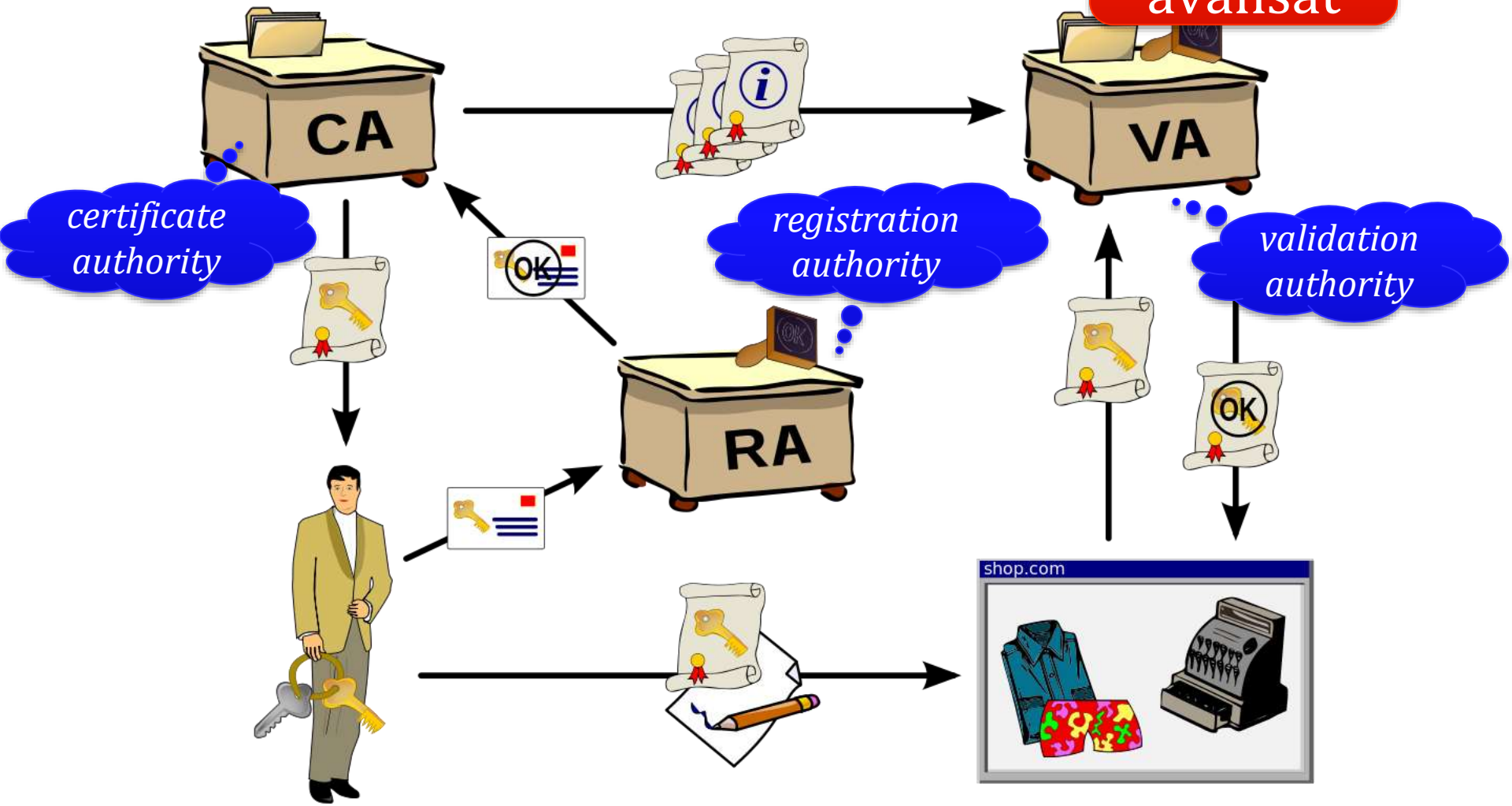
securitatea datelor

PKI (*Public Key Infrastructure*)
infrastructura bazată de chei publice

set de resurse hardware, software, umane + politici și proceduri pentru managementul certificatelor digitale (creare, distribuție, utilizare, stocare, revocare)

pentru Web, de considerat specificația
Web Authentication: An API for accessing Public Key Credentials (*W3C Recommendation*, 2021)
www.w3.org/TR/webauthn/

avansat



tutoriale (Herong Yang, 2020): **www.herongyang.com/PKI/**

PKI permite utilizatorilor să comunice „sigur” într-o rețea publică nesigură, inclusiv verificând identitatea unui utilizator via certificate digitale emise de o autoritate

securitatea datelor

Disponibilitatea

necesitatea ca o anumită resursă
să poată fi accesată la momentul oportun

avansat

securitatea datelor

Disponibilitatea

necesitatea ca o anumită resursă
să poată fi accesată la momentul oportun

aspect de interes: calitatea unui serviciu
stipulată via SLA (*Service-Level Agreement*)

uptime, average speed to answer, turn-around time,
abandonment rate, mean time to recover,...

avansat

SPARQL Endpoint	Uptime Last 24h	7 days
RUIAN - registry of land identification, addresses and properties of the Czech Republic	100%	41.07%
DBpedia in Portuguese	100%	43.45%
MONDIS	100%	50.6%
ELTE Digital Institutional Repository (EDIT)	100%	60.71%
demografiaataun	100%	94.05%
Drug Data from the Health Insurance Fund of Macedonia	100%	96.45%
Influence Tracker Dataset	100%	98.22%
DBTune.org Jamendo RDF Server	100%	99.4%
DBpedia in Basque	100%	99.4%
DBpedia in German	100%	99.4%
DBpedia in Greek	100%	99.4%
OpenEI - Open Energy Info	100%	99.4%
UNESCO Thesaurus	100%	99.4%
data.open.ac.uk, Linked Data from the Open University	100%	99.4%
A Short Biographical Dictionary of English Literature (RKBExplorer)	100%	100%
AEMET metereological dataset	100%	100%
Allie Abbreviation And Long Form Database in Life Science	100%	100%
AragoDBPedia	100%	100%

gradul de disponibilitate a unor servicii Web

aici, puncte-terminale SPARQL: **sparqles.ai.wu.ac.at/availability**

securitatea datelor

Disponibilitatea

cauze ale indisponibilității:

atacuri de refuz al serviciilor DoS (*Denial of Service*)

atacuri distribuite de tip DDoS (*Distributed DoS*)

implementare precară – exploatată de atacatori

securitatea datelor

Intimitatea

vizează drepturile ce trebuie respectate privind caracterul (subiectul) datelor vehiculate

confundată, deseori, cu confidențialitatea

securitatea datelor

Intimitatea

vizează drepturile ce trebuie respectate privind caracterul (subiectul) datelor vehiculate

prevederi legale:
EPIC (*Electronic Privacy Information Center*) – **www.epic.org**
EU GDPR (*General Data Protection Regulation*) – **eugdpr.org**

pentru Web: **www.w3.org/standards/webdesign/privacy**

securitatea datelor

Intimitatea

breșe:
stocarea necorespunzătoare a datelor
la nivel de server – *information disclosure*

atacuri de tip XSS (*Cross-Site Scripting*)

atacuri de tip *phishing* (practici frauduloase persuadând utilizatorii să ofere informații personale)

configurarea neadecvată a sistemelor

securitatea datelor

Securitatea Web trebuie să ia în considerație:

clientul

interacțiunea cu utilizatorul
date personale stocate: *cookie*-uri, date *off-line*, *cache*,...
transferurile asincrone – Ajax/WebSockets
rularea (neautorizată) de cod JavaScript/Web Assembly
existența *plugin*-urilor/extensiilor suspecte
...

securitatea datelor

Securitatea Web trebuie să ia în considerație:

datele aflate în tranzit

securitatea rețelei (cu/fără fir)
schimbul sigur de mesaje între diverse entități
nerepudierea datelor
vulnerabilitatea intermediarilor (*proxy*, *gateway*)
accesul la *cache*-ul intermediarilor
...

securitatea datelor

Securitatea Web trebuie să ia în considerație:

serverul

securitatea serverului/serverelor Web

securitatea aplicațiilor, *framework*-urilor, bibliotecilor, platformelor, infrastructurilor, sistemelor auxiliare,…

disponibilitatea serviciilor oferite – inclusiv, API-uri Web

securitatea datelor

Securitatea Web trebuie să ia în considerație:

clientul

datele aflate în tranzit

serverul

atacurile pot viza oricare din cele 3 aspecte!

securitatea datelor

Vulnerabilități

slăbiciuni ale unui sistem hardware/software ce permit utilizatorilor neautorizați să aibă acces asupra lui

pot apărea și datorită unei administrări precare

securitatea datelor

Vulnerabilități

niciun sistem nu este 100% sigur

Cum are loc
un atac informatic?

atacuri

Examinarea mediului

identificarea porturilor și serverelor publice

descoperirea tipurilor + versiunilor aplicațiilor/API-urilor

generarea de erori + examinarea mesajelor obținute

găsirea de informații sensibile:
cod-sursă, comentarii, câmpuri ascunse ale formularelor, fișiere de configurare/jurnalizare, SID-uri, jetoane JWT, URL-uri publice nesecurizate, chei de acces la API-uri, detalii privind platforma/infrastructura utilizată,…

SSL Certificates			
SSL by Default	Jun 2017	May 2021	
Sectigo SSL	May 2020	Dec 2020	⊘
Sectigo Domain SSL	May 2020	Dec 2020	⊘
Comodo SSL Root Authority	May 2015	May 2020	⊘
Comodo PositiveSSL	May 2015	May 2020	⊘
Comodo PositiveSSL Wildcard Wildcard	May 2015	May 2020	⊘
Name Server			
NSONE Enterprise DNS	Nov 2020	May 2021	$
Web Servers			
nginx	Jul 2012	May 2021	

inspectarea cu BuiltWith
a soluțiilor tehnologice folosite de o aplicație Web

atacuri

Stabilirea țintei atacului

maniera de autentificare (*login*) + crearea de conturi

câmpurile formularelor Web

managementul sesiunilor

platformă/infrastructură – intermediari (*e.g.*, *proxy*), servere de stocare a datelor, (micro-)servicii Web, API-uri REST/GraphQL, sisteme tradiționale (*legacy*),…

atacuri

La nivel de HTTP

analizarea pachetelor de date (*network sniffing*):
funcționează pentru fluxuri de date HTTP necriptate

o soluție de prevenire: HTTPS

atacuri

La nivel de HTTP

deturnarea sesiunilor (*session hijacking*):
atacatorul – *man-in-the-middle* – determină SID-ul utilizatorului și îl folosește în scop propriu

atacuri

La nivel de HTTP

deturnarea sesiunilor (*session hijacking*):
atacatorul – *man-in-the-middle* – determină SID-ul utilizatorului și îl folosește în scop propriu

exemplu: analizarea câmpului **Referer**

Referer: https://www.ebank.info/view/account?id=98151
&jsessid=BAC13606AC22B81E5137F45F95EE7573

atacuri

La nivel de HTTP

deturnarea sesiunilor (*session hijacking*):
atacatorul – *man-in-the-middle* – determină SID-ul utilizatorului și îl folosește în scop propriu

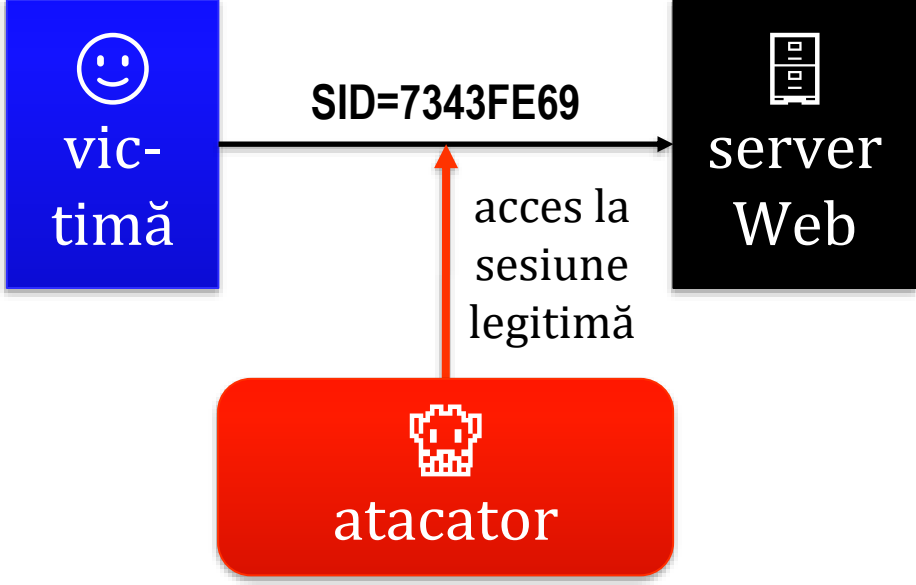
cazuri reale:
reutilizarea sesiunii Web
Twitter (8 februarie 2020) – **hackerone.com/reports/770504**
admin Web sessions remain active after logout
Shopify (5 august 2020) – **hackerone.com/reports/952035**

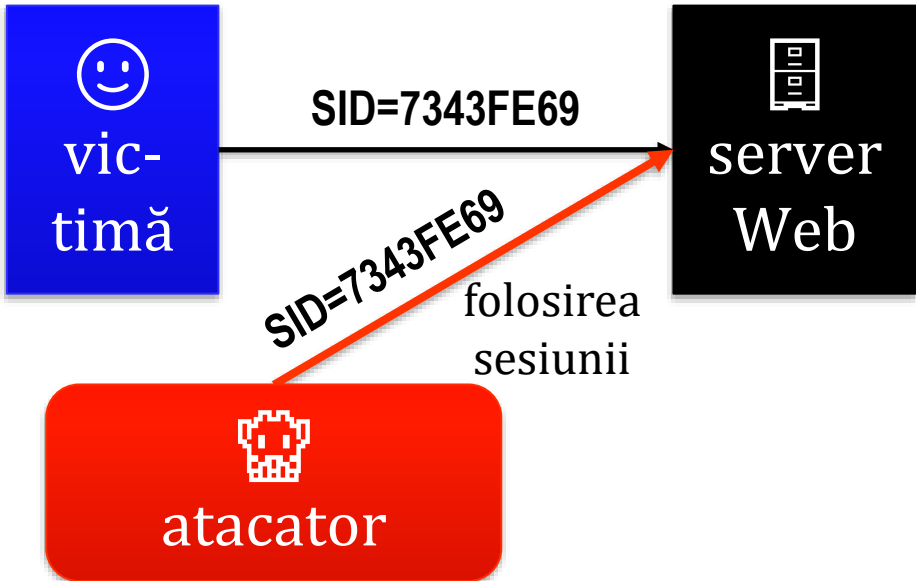
tehnici de preluare
a informațiilor despre
sesiunile Web:

interceptarea mesajelor
HTTP (*packet sniffing*)

atacuri de tip XSS
(*cross-site scripting*)

ghicirea identificatorului de
sesiune – SID (*blind attack*)





atacuri

La nivel de HTTP

deturnarea sesiunilor (*session hijacking*)

soluții clasice de prevenire:
eliminarea SID-ului din URL

stocarea SID-ului în câmpul **User-Agent**

utilizarea unui algoritm de generare a unui SID/*token* având o valoare impredictibilă

utilizarea unui SID variabil

atacuri

La nivel de HTTP

folosirea codului de stare HTTP pentru a expune date

detalii:

Abusing HTTP Status Codes to Expose Private Information (2011)

www.grepular.com/Abusing_HTTP_Status_Codes_to_Expose_Private_Information

Cross-Site Content and Status Types Leakage (2019)

medium.com/bugbountywriteup/cross-site-content-and-status-types-leakage-ef2dab0a492

atacuri

Server Side Request Forgery (SSRF)

abuz asupra funcționalității unui server Web pentru a accesa sau altera resurse interne

pe baza unui URL, atacatorul poate modifica parametri utilizați de o aplicație pentru a crea cereri malițioase

atacuri

Server Side Request Forgery (SSRF)

modus operandi + soluții de contracarare:

www.acunetix.com/blog/articles/server-side-request-forgery-vulnerability/

www.netsparker.com/blog/web-security/server-side-request-forgery-vulnerability-ssrf/

exemplificări reale:

GitLab (18 apr. 2020) – hackerone.com/reports/632101

Uppy NPM module (2 martie 2020) – hackerone.com/reports/786956

Vimeo (13 dec. 2019) – hackerone.com/reports/549882

atacuri

SQL injection

presupune scrierea unor interogări SQL care permit afișarea, alterarea, ștergerea de date din baze de date via formulare Web ori direct, folosind URL-uri

pentru detalii, de studiat *Testing for SQL Injection* (2020):
owasp.org/www-project-web-security-testing-guide/latest/

atacuri

SQL injection – exemplu:

SELECT * from customers where name=$name and pass=$pass

cu **$name** preluat din formular având valoarea **" or 1=1 --**

atacuri

SQL injection – exemplu:

https://e-banking.org/access_client.php?client=3

în *script*: **SELECT credit_card from clients where client=$client**

atacuri

SQL injection – exemplu:

https://e-banking.org/access_client.php?client=3

în *script*: **SELECT credit_card from clients where client=$client**

ce se întâmplă dacă URL-ul este
http://www.sit.org/access_client.php?client=client ?

dar dacă în loc de **SELECT** apărea comanda **DELETE**?

SQL injection

exemplificări reale – **laurent22.github.io/so-injections/**

inspectarea întrebărilor privind PHP plasate pe Stack Overflow

```
$sql = 'SELECT * from XXXXX where name = '" . $name . "'" ;

$query = $this->db->query("select * from form where ID='".$id."'");

$results = mysqli_query($db,"SELECT * FROM table_1 WHERE email='$email'");

$sql = "INSERT INTO hack(usr, psw) VALUES('$username', '$password')";

$s = "INSERT INTO kurse (userID, kursID) VALUES('{$_SESSION['userID']}','1')";

$sql = $con->query ("UPDATE users SET LogCount = " . $data['LogCount'] + 1 .
" WHERE Email_ID = '$email' ");

$db->query ("UPDATE Matchmaking SET MatchID=\"" . $matchID .
"\" WHERE RequestID=\"" . $result["RequestID"] . "\" OR UserID=\"" .
$_SESSION["OPTCG_ID"] "\"");
```

atacuri

SQL injection

variații:
crearea de interogări SQL incorecte
pentru a avea acces la mesaje de eroare „interesante”

atacuri

SQL injection – exemplu:

www.web.info/search?id=1+OR+xy=1

se poate obține un mesaj precum:

[Microsoft][ODBC SQL Server Driver] [SQL Server] Invalid column name 'xy'.

SELECT group_id, securityName, maxSalesCharge, price,

security_id, trade_date FROM funds

WHERE group_id = 1 OR xy=1 ORDER BY price DESC

atacuri

SQL injection – exemplu:

www.web.info/search?id=1+OR+xy=1

se poate obține un mesaj precum:

[Microsoft][ODBC SQL Server Driver] [SQL Server] Invalid column name 'xy'.

SELECT group_id, securityName, maxSalesCharge, price,
security_id, trade_date FROM funds
WHERE group_id = 1 OR xy=1 ORDER BY price DESC

atacatorul poate continua – de pildă – cu:

www.web.info/search?id=1;DELETE+FROM+funds+--

atacuri

SQL injection

soluții de prevenire:
„neutralizarea” meta-caracterelor SQL,
prepared statements, utilizarea de *framework*-uri ORM
(*Object-Relational Mapping*), proceduri stocate,...

incorect

```
$sql = "select * from users
   where user = '" . $user . "'";
```

corect

```
$rezultat = $db.query
  ("select * from users
    where user = ?", $user);
```

avansat

atacuri

SQL injection

soluții de testare a vulnerabilităților (*penetration tools*):

sqlmap – **sqlmap.org**
SQL Ninja – **sqlninja.sourceforge.net**
Vega – **subgraph.com/vega/**
Wapiti – **github.com/wapiti-scanner/wapiti**

resurse utile:
owasp.org/www-community/attacks/Blind_SQL_Injection

avansat

atacuri

NoSQL injection

exploatarea limbajului de programare disponibil în cadrul serverului NoSQL, inclusiv slăbiciunile API-ului oferit și/sau formatul de transfer al datelor (JSON, XML)

exemplificări: *Hacking Node.js and MongoDB* (2014)

blog.websecurify.com/2014/08/hacking-nodejs-and-mongodb.html

github.com/swisskyrepo/PayloadsAllTheThings/tree/master/NoSQL Injection

atacuri

Shell command injection

rularea de comenzi externe via *script*-uri CGI sau din cadrul serverelor de aplicații Web (PHP, Python, Ruby)

soluție de prevenire:
inhibarea folosirii funcțiilor system(), exec() etc.

atacuri

SQL injection + command injection

utilizarea SQL pentru execuția la nivel de *shell* de comenzi din cadrul serverului de baze de date

exemplu:

SELECT * FROM users WHERE name = 'tuxy' AND pass = ' '; xp_cmdshell 'taskkill /F /IM sqlservr.exe' --'

atacuri

XPath injection

recurgerea la expresii XPath pentru acces la date
într-un document XML sau pentru a realiza
diverse acțiuni via funcții XPath

consecințe și asupra transformărilor XSLT
considerate maligne ▸ pot cauza, de exemplu, DoS
detalii la **www.agarri.fr/blog/**

atacuri

Path traversal

posibilitatea de accesare a unor zone nepermise ale sistemului de fișiere – *i.e.*, în afara directoarelor în care rezidă aplicația Web

exemplificare:

e-photos.info/photos/list.jsp?dir=../../

exemplu real: Cisco ASA (20 mai 2019): **hackerone.com/reports/378698**

alt caz: module Node.js (1 apr. 2019): **hackerone.com/reports/510043**

atacuri

Path traversal

posibilitatea de accesare a unor zone nepermise ale sistemului de fișiere – *i.e.*, în afara directoarelor în care rezidă aplicația Web

exemplu în contextul XML (XXE – *XML External Entity*):
cwe.mitre.org/data/definitions/611.html

```
<!DOCTYPE doc [ <!ENTITY xxe SYSTEM "file:///tmp/sessions/..."> ]>
```

atacuri

Poisonous null-byte attack

folosirea caracterului NULL pentru plasarea de *script*-uri pe server ce ulterior pot fi executate

exemplu:
upload-ul unei „imagini” – **img.php%00.jpg**
“*Thank you! See your picture at* img.php”

atacuri

Cross-Site Scripting (XSS)

permite „injectarea” în cadrul sistemului,
pentru execuția direct în *browser*,
a programelor JavaScript

funcționează mai ales în cadrul siturilor Web interactive
(*e.g.*, forumuri Web, *blog*-uri, *wiki*-uri)

tutorial: **www.hacker101.com/sessions/xss**

avansat

atacuri

Stored XSS

atacatorul injectează un program JS (denumit și *payload*)
care e stocat permanent în cadrul aplicației țintă

e.g., în baza de date a aplicației Web
de tip CMS (*Content Management System*)

exemplificări:
Steam Community (25 mai 2018): **hackerone.com/reports/351171**
Starbucks UK (23 mai 2018): **hackerone.com/reports/227486**

avansat

atacuri

Reflected XSS

script-ul de tip *payload* este transmis de serverul Web al atacatorului ca parte a unui mesaj de răspuns HTTP (codul malițios e livrat de la distanță fiecărei victime)

utilizatorul e persuadat să viziteze un URL special via tehnici de *social engineering* (*e-mail*, rețele sociale,...)

avansat

atacuri

Reflected XSS

script-ul de tip *payload* este transmis de serverul Web al atacatorului ca parte a unui mesaj de răspuns HTTP (codul malițios e livrat de la distanță fiecărei victime)

Reflected XSS explained (2018): **blog.sqreen.io/reflected-xss/**

exemplu: OLX (8 decembrie 2018): **hackerone.com/reports/429647**

avansat

atacuri

DOM-based XSS

payload-ul este stocat – în urma unei manipulări ilegale (referențiere și utilizare) a codului JS – în arborele DOM disponibil la nivel de *browser*

avansat

atacuri

DOM-based XSS

payload-ul este stocat – în urma unei manipulări ilegale (referențiere și utilizare) a codului JS – în arborele DOM disponibil la nivel de *browser*

detalii (2019):
www.netsparker.com/blog/web-security/dom-based-cross-site-scripting-vulnerability/

caz real: ZEIT (16 mai 2019): **hackerone.com/reports/545121**

atacuri

XSS – exemple tipice:

<img src="javascript:cod" />
redirecționează utilizatorul spre alt URL,
preia valori de *cookie*-uri ori blochează *browser*-ul

includerea de cod malițios (*malware*)
spre a fi executat la nivel de *browser*
via elemente precum **<iframe>**, **<img>** sau **<video>**

avansat

atacuri

XSS – alte acțiuni malefice:

```
<script>
setInterval ( () => {
  var w = window.open ();
  w.document.write (document.documentElement.outerHTML ||
                    document.documentElement.innerHTML);
  }, 33);
</script>
```

crearea recursivă
de ferestre via DOM
(à la *fork bomb*)

avansat

atacuri

XSS – alte acțiuni malefice:

plasarea de programe *malware*
în cadrul unei aplicații Web – *e.g.*, cod jQuery fals

studii de caz – cel mai recent descris pe 17 mai 2021:
Object Injection Vulnerability Affects WordPress
"PHP Object Injection is an application level vulnerability that could allow an attacker to perform different kinds of malicious attacks, such as Code Injection, SQL Injection, Path Traversal *and* Application Denial of Service*, depending on the context."*

blog.sucuri.net/category/website-malware-infections

atacuri

Cross-Site Request Forgery (CSRF)

forțează utilizatorul autentificat în cadrul unei aplicații să execute acțiuni nedorite – *e.g.*, alterarea datelor

Cross-Site Request Forgery (CSRF)

cazuri concrete:

modificarea adresei poștale + închirierea de filme de către persoanele având cont la Netflix (2006)

vulnerabilitate OAuth în Periscope Producer API (2017)
blog.innerht.ml/testing-new-features/

acces cu GraphQL la un cont Facebook via Oculus (2018)
www.josipfranjkovic.com/blog/hacking-facebook-oculus-integration-csrf

control asupra contului la Khan Academy (17 mai 2019)
hackerone.com/reports/442901

atac la nivel de API pentru delivery-club.ru (25 feb. 2020)
hackerone.com/reports/690812

atacuri

Cross-Site Request Forgery (CSRF)

poate conduce și la furtul identității (*phishing*)
sau la plasarea de cod *malware* la client

owasp.org/www-community/attacks/csrf

o soluție de contracarare:
biblioteca CSRFGuard
github.com/aramrami/OWASP-CSRFGuard

atacuri

Cross Site History Manipulation (CSHM)

breșă de securitate eludând *Same Origin Policy*,
ce permite manipularea istoricului navigării
de către un program malițios – *e.g.*, detectarea stării de
autentificare a utilizatorului pe un sit, *user tracking*,
acces la parametrii asociați unui URL,...

tinyurl.com/qyurynm

atacuri

Alte atacuri Web de tip *phishing*

folosirea de cod JavaScript pentru a modifica textul redat de navigatorul Web utilizatorului sau pentru a manipula utilizatorul să viziteze legături ascunse

clickjacking
UI redress attack

owasp.org/www-community/attacks/Clickjacking

atacuri

Alte atacuri Web de tip *phishing*

folosirea de cod JavaScript pentru a modifica textul redat de navigatorul Web utilizatorului sau pentru a manipula utilizatorul să viziteze legături ascunse

modus operandi (2018): **blog.innerht.ml/google-yolo/**

caz real (2019):
Clickjacking VKpay – **hackerone.com/reports/374817**

atacuri

Alte atacuri Web de tip *phishing*

folosirea de cod JavaScript pentru a genera într-un *tab* al navigatorului o replică a unui formular de autentificare în cadrul unei aplicații – *e.g.*, Facebook, GMail

tabnabbing

de studiat și **owasp.org/www-community/attacks/Reverse_Tabnabbing**

atacuri

Alte atacuri Web de tip *phishing*

adoptarea de tehnici de *social engineering*
"any act that influences a person to take an action that may or may not be in their best interest"

manipularea utilizatorilor – *e.g.*, furtul de parole – prin intimidare, șantaj, autoritate, flatare, substituție de persoană, vanitate etc.

www.social-engineer.org

atacuri

Exemple reale:

Email spam campaign impersonating Google Docs (2017)
reddit.com/r/google/comments/692cr4/new_google_docs_phishing_scam_almost_undetectable/

Anatomy of an Amazon Phishing Attack (2017)
shkspr.mobi/blog/2017/01/anatomy-of-an-amazon-phishing-attack/

Open Redirect Vulnerability @ Rockstar Games (2019)
hackerone.com/reports/380760

PayPal Android: Remote Theft of User Session (2019)
hackerone.com/reports/424443

atacuri

Soluții de contracarare:

inhibarea folosirii marcajelor HTML

HTML *escaping* via o bibliotecă specializată

filtrarea marcatorilor

separarea prezentării datelor de procesarea efectivă

etc.

cheatsheetseries.owasp.org/cheatsheets/Cross_Site_Scripting_Prevention_Cheat_Sheet.html

atacuri

Probleme cauzate de URI/IRI-uri

inducerea în eroare a utilizatorului
asupra domeniului Internet a sitului Web
exemplu: **http://www.reddit.com@63.241.3.69/**
+
codificarea defectuoasă a codurilor hexa

- vulnerabilități în cadrul unor servere Web

atacuri

Probleme cauzate de URI/IRI-uri

includerea caracterelor Unicode
probleme la decodificarea URL-urilor considerate „sigure”

atacuri

Probleme cauzate de URI/IRI-uri

siturile având domenii internaționale
(IDN – *International Domain Names*)

- atacuri bazate pe homografie

detalii la **www.unicode.org/reports/tr36/**

exemple:
www.xudongz.com/blog/2017/idn-phishing/
hackerone.com/reports/384569

avansat

atacuri

Manipularea datelor din *cache* – *Web Cache Deception*

realitate: prevalența *cache*-urilor la diverse niveluri (*browser* Web, *proxy*, *gateway* Web, server Web, CDN,...)

modus operandi: accesarea și/sau alterarea neautorizată a datelor disponibile în *cache*

avansat

atacuri

Manipularea datelor din *cache* – *Web Cache Deception*

detalii de interes:
J. Kettle, “Practical Web Cache Poisoning”,
Portswigger Research, 2021
portswigger.net/research/practical-web-cache-poisoning

S. A. Mirheidari *et al.*, “Cached and Confused: Web Cache Deception in the Wild”, *USENIX Security Symposium*, 2020
arxiv.org/abs/1912.10190

avansat

atacuri

Manipularea datelor din *cache* – *Web Cache Deception*

exemplificări concrete:

CPDoS (*Cache Poisoned Denial of Service*) – **cpdos.org**

Discourse (18 nov. 2018) – **hackerone.com/reports/394016**

vulnerabilitate PayPal descrisă de
O. Gil, *Web Cache Deception Attack* (2017)
omergil.blogspot.com/2017/02/web-cache-deception-attack.html

atacuri

Probleme privind folosirea parolelor

majoritatea proceselor de autentificare utilizează parole

atacuri

Probleme privind folosirea parolelor

cu cât utilizatorul trebuie să rețină mai multe parole, cu atât sistemul de autentificare via parole e predispus la breșe de securitate:
alegerea unor parole slabe, folosite timp îndelungat

partajarea parolelor în grupuri de prieteni/colegi

scrierea parolelor pe hârtie – eventual, la vedere

recurgerea la aceeași parolă pentru aplicații Web multiple

atacuri

Probleme privind folosirea parolelor

exemplu de atac:
pe baza unui dicționar sau *brute-force* asupra Twitter
▸ descoperirea parolei "*happiness*"
asociată unui cont cu drepturi de administrare
blog.codinghorror.com/dictionary-attacks-101/

soluție tipică de prevenire:
conturi de administrare separate de conturile normale

atacuri

Troienii Web

situri/aplicații Web aparent folositoare,
la care utilizatorul poate ajunge
eventual via redirectare automată

suplimentar, pot recurge la XSS/CSRF
sau la tehnici de tip *social engineering*

atacuri

Troienii Web

exemple: antiviruși falși, achiziții online de produse farmaceutice, software modificat de căutare pe Web

reclame abuzive (*large-scale abusive advertising*)

+

escrocare via plăți electronice (card de credit ori Bitcoin)

cseweb.ucsd.edu/~savage/papers/CCS12Priceless.pdf

atacuri

Exemple:
injectarea de biblioteci JS măsluite
în cadrul CMS-urilor – *e.g.*, Joomla, Wordpress,…

Fake jQuery Scripts in Nulled WordPress Plugins
blog.sucuri.net/2015/05/fake-jquery-scripts-in-nulled-wordpress-pugins.html
jQuery.min.php Malware Affects Thousands of Websites
blog.sucuri.net/2015/11/jquery-min-php-malware-affects-thousands-of-websites.html

injectarea de *plug-in*-uri false
de exemplu, bbPress la WordPress
blog.sucuri.net/2017/01/fake-bb_press-plugin.html

Situație concretă: injectarea în *browser* (inclusiv pe platforme mobile) a unor programe JS – *script*-uri la distanță sau cod *ransomware* inclus în imagini – pretinzând existența unor actualizări pentru a fi inițiate atacuri

EXE

14 / 72

File name	browser.jpg
File size	2.12 MB
Last analysis	2019-02-25 13:55:47 UTC

Detection | Details | Relations | Community

Acronis	suspicious
CrowdStrike Falcon	malicious_confidence_100%
Cylance	Unsafe
Endgame	malicious (high confidence)
ESET-NOD32	a variant of Win32/Kryptik.GF
Fortinet	W32/Kryptik.GOUT!tr.ransom
Ikarus	Trojan-Ransom.Crypted007
Qihoo-360	HEUR/QVM20.1.7721.Malwar
Rising	Ransom.Cerber!8.3058 (TFE:2

D. Sinegubko, *Fake Browser Updates Push Ransomware and Bank Malware* (2019)

blog.sucuri.net/2019/02/fake-browser-updates-push-ransomware-and-bank-malware.html

(în loc de) pauză

atacuri

Refuz de servicii (*denial of service*)

exploatarea unor componente ale aplicației astfel încât funcționalitățile să nu poată fi oferite clienților reali

uzual, inițierea de procesări recursive
(eventual, via programe care se autoreproduc)

avansat

atacuri

Refuz de servicii (*denial of service*)

exploatarea unor componente ale aplicației astfel încât funcționalitățile să nu poată fi oferite clienților reali

uzual, inițierea de procesări recursive
(eventual, via programe care se autoreproduc)
fork bomb – *e.g.*, în Ruby: **loop { fork { __FILE__ } }**
XML bomb
zip bomb – **research.swtch.com/zip**

Exemplu real (*billions of lols*)

```
<?xml version="1.0"?>
<!DOCTYPE lolz [
  <!ENTITY lol "lol">
  <!ENTITY lol1 "&lol;&lol;&lol;&lol;&lol;&lol;&lol;&lol;&lol;&lol;">
  <!ENTITY lol2 "&lol1;&lol1;&lol1;&lol1; &lol1;&lol1;&lol1;&lol1;&lol1;">
  <!ENTITY lol3 "&lol2;&lol2;&lol2;&lol2;&lol2;&lol2;&lol2;&lol2;&lol2;">
  <!ENTITY lol4 "&lol3;&lol3;&lol3;&lol3;&lol3;&lol3;&lol3;&lol3;&lol3;">
  ...
  <!ENTITY lol8 "&lol7;&lol7;&lol7;&lol7;&lol7;&lol7;&lol7;&lol7;&lol7;">
  <!ENTITY lol9 "&lol8;&lol8;&lol8;&lol8;&lol8;&lol8;&lol8;&lol8;&lol8;">
]>
<lolz>&lol9;</lolz>
```

B. Sullivan, *XML Denial of Service Attacks and Defenses* (2009)
msdn.microsoft.com/magazine/ee335713

tehnici de prevenire:
cheatsheetseries.owasp.org/cheatsheets/XML_External_Entity_Prevention_Cheat_Sheet.html

atacuri

Ransomware

încetarea unui tip de atac asupra unui sit Web – *e.g.*, DDoS sau criptarea conținutului – doar dacă proprietarul plătește o „taxă de protecție” (*i.e.* folosind Bitcoin)

exemplificări concrete:

blog.sucuri.net/2015/12/ddos-extortions-campaigns.html

blog.sucuri.net/2016/01/ransomware-strikes-websites.html

avansat

atacuri

Ransomware

The OWASP Anti-Ransomware Guide:
github.com/OWASP/www-project-anti-ransomware-guide

detecție via capcane – *honeypots* + *honeynets*
www.honeynet.org

C. Moore, *Detecting Ransomware with Honeypot Techniques* (2016)
www.academia.edu/30050595/Detecting_Ransomware_with_Honeypot_techniques

atacuri

Tentative de acces la resurse presupus vulnerabile ori la secțiuni de administrare a unui sit Web

208.113.197.80 GET /wp-admin/
5.196.16.176 GET /~jromai/romaijournal//images/stories/post.gif
185.22.64.241 GET /~busaco/docs/jdownloads/screenshots/has.php.j?rf
5.196.16.176 POST /index.php?option=com_jce&task=plugin&file=imgmanager&method=form&cid=20&6bc427c8a7981f4fe1f5ac65c=cf6dd3cf1923c950586
38.87.45.121 GET /~vcosmin/WikiLogica/index.php?title=BuckYoung847
74.220.207.111 GET /wp-admin/admin-ajax.php?action=revslider_ajax_action
74.220.207.111 GET /index.php?gf_page=upload
195.30.97.113 POST //index.php?option=com_jdownloads&Itemid=0&view=upload
5.153.237.232 POST /~flash/wiki/index.php?title=Special:Userlogin&action=submitlogin
46.102.103.137 POST /~flash/wiki/index.php?title=Special:Userlogin&action=submitlogin

atacuri

Detectarea posibilelor vulnerabilități
– datorate unor configurații incorecte/implicite
ale serverelor și/sau aplicațiilor Web –
se poate realiza apelând la un motor de căutare

Exemple de acțiuni:

detecția versiunilor de programe cu *bug*-uri cunoscute:
"Apache/2.4.43 server at"

accesul la fișiere *.bak*: **inurl:index.php.bak**

detectarea paginilor de administrare: **"admin login"**

instalări implicite: **intitle:"welcome to" intitle:internet IIS**

localizarea interfețelor spre sisteme de baze de date:
inurl:main.php phpMyAdmin

căutarea de aplicații ori a fișierelor de jurnalizare:
inurl:error.log +filetype:log –cvs

mesaje de eroare generate de aplicații ori servere de baze de date: **"ASP.NET_SessionId" "data source="**

avansat

PHP	176,761
JavaScript	157,954
Python	14,922
HTML	13,865
C	12,343
VimL	2,514
HTML+ERB	1,934
Ruby	740
Text	683
JSON	415

alternativă: căutarea de programe potențial vulnerabile în depozite de cod-sursă disponibile public

cazul GitHub: detecția execuției de cod – *e.g.*, **exec($_GET**

Metode de prevenire a atacurilor?

avansat

prevenirea

La nivel de servere de aplicații/platforme Web

exemplificări diverse:

ASP.NET Core – **docs.microsoft.com/aspnet/core/security/**

Node.js – **hackerone.com/nodejs-ecosystem**

PHP – **phpsecurity.readthedocs.org**

Python – **www.pythonsecurity.org**

altele la **github.com/OWASP/CheatSheetSeries**

avansat

prevenirea

Securitatea serviciilor (API-urilor) Web

folosirea obligatorie a HTTPS

+

certificate digitale actualizate

avansat

prevenirea

Securitatea serviciilor (API-urilor) Web

datele „sensibile” nu trebuie expuse în URL

corect:
https://web.info/resourceCollection/[ID]/action

incorect:
http://web.info/controller/7/action?apiKey=s74b1901c07

avansat

prevenirea

Securitatea serviciilor (API-urilor) Web

permiterea accesului la API doar prin cheie (*API key*)
+
verificarea acestei chei pentru fiecare cerere în parte

utilizatorii trebuie să recurgă
la un mecanism solid de autentificare

avansat

prevenirea

Securitatea serviciilor (API-urilor) Web

privilegii reduse: restricționarea metodelor HTTP
de pildă, doar GET
+
folosirea de liste de clienți/utilizatori agreați (*whitelist*)

avansat

prevenirea

Securitatea serviciilor (API-urilor) Web

utilizarea OAuth pentru autorizare

a se considera și schimbul de date
via JWT (*JSON Web Tokens*) pentru controlul accesului

avansat

prevenirea

Securitatea serviciilor (API-urilor) Web

validarea datelor de intrare
(parametri, câmpuri de antet HTTP,...)

aspecte: lungime, tip de date, format, valori permise
cereri având date neașteptate/dubioase trebuie rejectate
+
verificarea – și, eventual, validarea – tipului conținutului

avansat

prevenirea

Securitatea serviciilor (API-urilor) Web

tratarea erorilor:
recurgerea la mesaje generice și
evitarea transmiterii detaliilor tehnice clientului
+
jurnalizarea și analizarea cererilor (*audit logs*)

avansat

prevenirea

Securitatea serviciilor (API-urilor) Web

folosirea adecvată a codurilor de stare HTTP
www.restapitutorial.com/httpstatuscodes.html

contra-exemplu:
orice succes via 200 *OK*
orice situație de eroare raportată cu 404 *Not Found*

avansat

prevenirea

Securitatea serviciilor (API-urilor) Web

recurgerea la anteturi HTTP
vizând securizarea transferului datelor

owasp.org/www-project-secure-headers/

ghid util (2019): **www.keycdn.com/blog/http-security-headers**

avansat

prevenirea

Securitatea serviciilor (API-urilor) Web

prevenirea atacurilor exploatând vulnerabilități GraphQL

tipuri de atacuri:
interogări GraphQL problematice (*GraphQL injection*)

probleme de autentificare

information disclosure (*GraphQL instrospection attack*)

abuzuri (*e.g., GraphQL batching attack*)

cheatsheetseries.owasp.org/cheatsheets/GraphQL_Cheat_Sheet.html

avansat

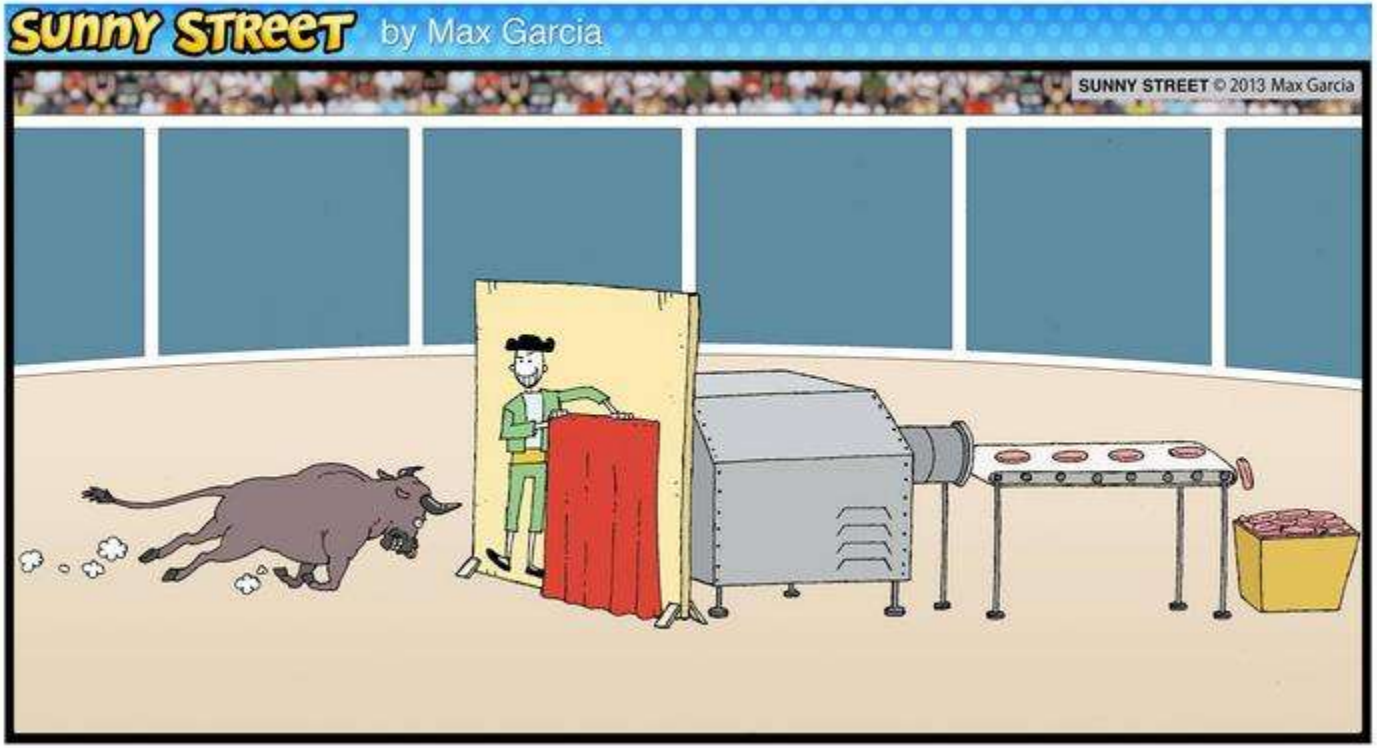
prevenirea

Securitatea serviciilor (API-urilor) Web

prevenirea atacurilor exploatând vulnerabilități GraphQL

tutorial (Wan Ariff, decembrie 2019):
threatninja.net/tutorial-on-graphql-injection/

instrumente software – exemple:
GraphQLmap – **github.com/swisskyrepo/GraphQLmap**
InQL – **github.com/doyensec/inql**



Modalități de supraviețuire în caz de atac?

supraviețuirea

Sistemul trebuie să-și ducă până la capăt misiunea chiar dacă unele componente/părți din sistem sunt afectate ori scoase din uz

îndeplinirea funcționalităților vitale (*mission-critical*)

- identificarea serviciilor esențiale

exemplu:
oferirea unei copii *read-only* a conținutului

supraviețuirea

Proprietăți importante ale sistemului:

rezistența la atacuri

recunoașterea atacurilor și efectelor lor

adaptarea la atacuri

avansat

supraviețuirea

Rezistența la atacuri

strategii de respingere a atacului:

validarea obligatorie a datelor

autentificarea utilizatorilor

acordarea privilegiilor minime

acces la servicii Web ori API-uri doar pe baza unei chei

...

avansat

supraviețuirea

Recunoașterea atacurilor și efectelor lor

strategii pentru restaurarea datelor, limitarea efectelor, menținerea/restaurarea serviciilor compromise

ferme de servere Web (*Web farms*) – eventual, în *cloud*
RAID (*Redundant Array of Independent Disks*)
SAN (*Storage Area Network*)
copii de siguranță (*backup*-uri): complete/incrementale
...

avansat

supraviețuirea

Adaptarea la atacuri

strategii pentru îmbunătățirea nivelului (șansei) de supraviețuire

analiză (audit)
învățarea din greșeli
recurgerea la expertiza unor companii specializate
...

avansat

răspunsul la incidente

Răspunsurile agresive – *e.g., hack back* – sunt prohibite

avansat

răspunsul la incidente

Răspunsurile agresive – *e.g., hack back* – sunt prohibite

uzual, se recurge la metodologia SANS
(*System Administration, Networking, and Security*)

etape:
pregătire ▸ identificare ▸ controlul efectelor (*containment*)
▸ eradicare ▸ recuperare ▸ continuare (*follow-up*)
www.sans.org/security-resources/

avansat

răspunsul la incidente

Forensics

proces de „prindere” a *cracker*-ilor

investigation of digital evidence
for use in criminal or civil courts of law

forensicswiki.xyz

avansat

răspunsul la incidente

Forensics

uzual, are loc după un incident de securitate

implică analizarea *hardware*-ului (discuri, RAM), „deșeelor” (*information detritus*), *log*-urilor, fișierelor de configurare și altele

diverse instrumente software – bazate pe Linux:
resources.infosecinstitute.com/topic/computer-forensics-tools/

avansat

răspunsul la incidente

Forensics

acțiunea de „ștergere” a urmelor = ***anti-forensics***

o serie de detalii la
forensicswiki.xyz/wiki/index.php?title=Anti-forensic_techniques

monitorizare & testare

Teste de verificare a…

capacității de deservire a clienților

robusteței

rulării în situații extreme

monitorizare & testare

Se iau în considerație:

caracteristicile *browser*-ului Web (+setările implicite)

platforma/platforme: hardware, sistem de operare,...

interfața: rezoluția ecranului, adâncimea de culoare,...

politica de *caching* (+siguranța *proxy*-ului)

suportul pentru redarea unor tipuri de documente (securitatea folosirii *plugin*-urilor)

limbajul/limbajele de programare utilizate (inclusiv serverul/serverele de aplicații, bibliotecile etc.)

avansat

monitorizare & testare

Teste specifice legate de programare:

depășiri de *buffer*-e (*buffer overflow*)

exemplu: lungimea URI-urilor trimise de client

caz real:
Apple iTunes for Windows (versiunea < 8.2) permitea execuția de cod arbitrar la utilizarea schemei URL itms:
www.securitytracker.com/id/1022313

avansat

monitorizare & testare

Teste specifice legate de programare:

probleme de prelucrare (*parsing*)

procesarea URI-urilor, a datelor primite via formulare, *cookie*-uri, entităților (X)HTML, datelor XML, cererilor HTTP, XML-RPC și SOAP, interogărilor SQL, datelor JSON, datelor YAML etc.

N. Seriot, *Parsing JSON is a Minefield* (2018): **seriot.ch/parsing_json.php**

avansat

monitorizare & testare

Teste specifice legate de programare:

probleme de conversie a datelor + (de)serializare

de exemplu, ASCII ↔ Unicode

reguli de bună practică:
RFC 5137 – **tools.ietf.org/html/rfc5137**

avansat

monitorizare & testare

Teste specifice legate de programare:

probleme de redare a datelor

exemplificare:
afișarea perechii *nume prenume* atunci când

```
nume="<script>document.location="
prenume="'un_uri'</script>"
```

avansat

monitorizare & testare

Teste specifice legate de programare:

probleme de *escaping*

exemplu:
character escaping pentru șirul cs/b

cs%2Fb
cs%%252Fb
cs%25%32%46b

avansat

monitorizare & testare

Teste specifice legate de programare:

probleme de *escaping*

„injectare” directă a datelor via URI sau prin intermediul interfeței Web sau via un fișier (*upload* ilegal) ori folosind un program (*e.g.*, de administrare la distanță a aplicației),...

- verificarea *escaping*-ului via instrumente dedicate

monitorizare & testare

Soluții și strategii:

programare defensivă
(*defensive programming*)

adoptarea standardelor de redactare a codului
(*enforcing coding standards*)

recurgerea la unități de testare
(*unit testing*)

monitorizare & testare

Soluții și strategii:

includerea unui sistem de prevenire, detectare și raportare a erorilor survenite în cod
+ un sistem de urmărire a *bug*-urilor (*bug tracking*)

folosirea unui sistem de control al versiunilor

a se revedea cursul privitor la inginerie Web

avansat

monitorizare & testare

Teste specifice legate de intimitate (*privacy*):

datele obținute de la utilizator trebuie tratate ca fiind sigure și confidențiale

Ce date vor fi disponibile în *cache*-ul clientului?

Cookie-urile/datele din LocalStorage pot conține date sensibile, posibil de exploatat de persoane rău-voitoare?

Cum se invalidează *cache*-ul?

monitorizare & testare

Teste privitoare la integrarea componentelor:

gradul de securitate al unei aplicații
este dat de gradul de securitate
al celei mai vulnerabile componente

monitorizare & testare

Teste privitoare la integrarea componentelor:

gradul de securitate al unei aplicații
este dat de gradul de securitate
al celei mai vulnerabile componente

neverificarea validității identificatorului de utilizator la nivel de server, pe baza faptului că această verificare s-a efectuat deja la nivelul *browser*-ului Web

caz real: **darkport.co.uk/blog/dominos-pizza-and-payments/**

avansat

monitorizare & testare

Teste privind opacizarea datelor (*obfuscation*):

datele nu trebuie stocate în locații predictibile

conținutul propriu-zis poate conduce
la probleme de securitate – *information disclosure*

e.g., acces la Webcam – context: IoT (*Internet Of Things*)
darkport.co.uk/blog/a-close-look-at-the-philips-in-sight-ip-camera-range/

avansat

monitorizare & testare

Breșe referitoare la *information disclosure*:

accesarea câmpurilor ascunse ale formularelor Web
și/sau
a comentariilor din codul-sursă HTML, CSS, JavaScript

avansat

monitorizare & testare

Breșe referitoare la *information disclosure*:

consultarea fișierului **robots.txt**

- scanarea fișierelor de configurare sau a directoarelor temporare – *e.g.*, rapoarte ale traficului

```
User-agent: *
Disallow: /plenum/data/5510903.doc
Disallow: organization/193959.pdf
Disallow: /en/community/thread/12819
...
```

avansat

monitorizare & testare

Breșe referitoare la *information disclosure*:

mesaje de eroare emise de aplicații și/sau API-uri

fișiere având extensii incorecte

- acces la codul-sursă al *script*-urilor de pe server

vizualizarea conținutului directoarelor serverului

scanarea traficului de rețea
(URI-uri, date XML/JSON transmise asincron,...)

Express

avansat

500 **TypeError: /usr/local/sparqles/node/views/content/performance.jade:45 43| span(onmouseover='tooltip.show(\'#{configPerformance["Cold-Warm"]}\')', onmouseout='tooltip.hide();') (Cold-Warm) 44| tbody > 45| - each ep, i in ptasks_agg 46| tr(class=(i % 2 == 0) ? 'odd' : 'even') 47| //-Display Endpoint Label 48| //-TODO: if more than one endpoint then display how many and their names Cannot read property 'length' of undefined**

```
43| span(onmouseover='tooltip.show(\'#{configPerformance["Cold-Warm"]}\')', onmouseout='tooltip.hide();') (Cold-Warm)
44| tbody
> 45| - each ep, i in ptasks_agg
46| tr(class=(i % 2 == 0) ? 'odd' : 'even')
47| //-Display Endpoint Label
48| //-TODO: if more than one endpoint then display how many and their names

Cannot read property 'length' of undefined
at jade_debug.unshift.lineno (eval at (/usr/local/sparqles/node/node_modules/jade/lib/jade.js:179:8), :708:31)
at eval (eval at (/usr/local/sparqles/node/node_modules/jade/lib/jade.js:179:8), :1061:4)
at eval (eval at (/usr/local/sparqles/node/node_modules/jade/lib/jade.js:179:8), :1378:22)
at res (/usr/local/sparqles/node/node_modules/jade/lib/jade.js:180:38)
at Object.exports.render (/usr/local/sparqles/node/node_modules/jade/lib/jade.js:305:10)
at Object.exports.renderFile (/usr/local/sparqles/node/node_modules/jade/lib/jade.js:341:18)
at View.exports.renderFile [as engine] (/usr/local/sparqles/node/node_modules/jade/lib/jade.js:326:21)
at View.render (/usr/local/sparqles/node/node_modules/express/lib/view.js:76:8)
at Function.app.render (/usr/local/sparqles/node/node_modules/express/lib/application.js:505:10)
at ServerResponse.res.render (/usr/local/sparqles/node/node_modules/express/lib/response.js:756:7)
```

acces nedorit la datele privind erorile survenite + codul-sursă al unei aplicații Web (aici, Node.js recurgând la *framework*-ul Express)

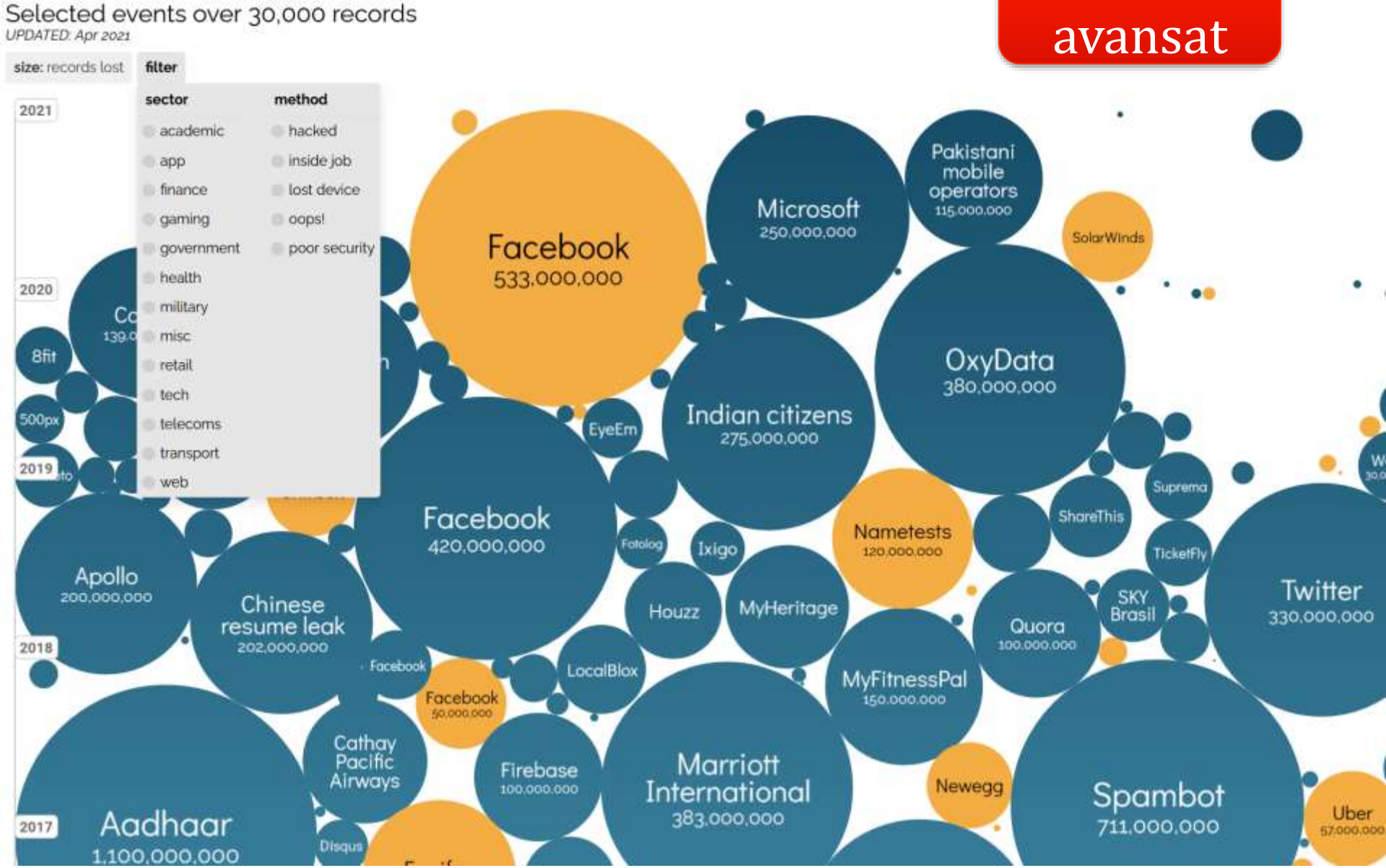
avansat

monitorizare & testare

Breșe referitoare la *information disclosure*:

accesul neautorizat la datele private ale utilizatorilor având conturi pe diverse aplicații Web – *data breach*

avansat



World's Biggest Data Breaches & Hacks (aprilie 2021)

informationisbeautiful.net/visualizations/worlds-biggest-data-breaches-hacks/

avansat

monitorizare & testare

Teste specifice legate de exploatare:

pregătirea judicioasă a exploatării în practică (*deployment*)

detectarea problemelor de flux

tratarea corespunzătoare a codurilor HTTP 4xx și 5xx, acces la resurse autentificate (*e.g.*, obținerea unor date fără autentificarea prealabilă a utilizatorului), execuția anormală a *script*-urilor etc.

avansat

monitorizare & testare

Teste specifice legate de exploatare:

testarea interacțiunii cu aplicația Web

- biblioteci/programe simulând vizitatori virtuali

exemple: Playwright, Puppeteer, Selenium, WebdriverIO

realizarea testelor de încărcare (*load testing*)

- scenarii și interpretarea rezultatelor

avansat

monitorizare & testare

Instrumentele de stresare (*stressing tools*)
pot oferi informații privitoare la…

performanță

e.g., timp de răspuns, timp de generare a conținutului,…

de parcurs și resursele disponibile la
profs.info.uaic.ro/~busaco/teach/courses/staw/web-film.html#week13

avansat

monitorizare & testare

Instrumentele de stresare (*stressing tools*)
pot oferi informații privitoare la…

scalabilitate

memorie ocupată, utilizarea discului, numărul de conexiuni privind alte servicii, comportament etc.

avansat

monitorizare & testare

Instrumentele de stresare (*stressing tools*)
pot oferi informații privitoare la…

corectitudine + robustețe

rapoarte privind funcționarea
(eronată a) unor componente

e.g., pe baza fișierelor de jurnalizare (*log*-uri)

avansat

monitorizare & testare

Instrumentele de stresare (*stressing tools*)
pot oferi informații privitoare la…

corectitudine + robustețe

context mai larg:
SRE (*Site Reliability Engineering*)

resurse:
landing.google.com/sre/books/

avansat

monitorizare & testare

Instrumentele de stresare (*stressing tools*) pot oferi informații privitoare la…

lacune de securitate

avansat

instrumente (exemple)

Arachni, **Grabber**, **Nuclei**, **Ride** (*REST JSON Payload fuzzer*),
Sec-helpers, **w3af**, **Wikto**, **Zed Attack Proxy**
scanare de vulnerabilități

Astra Security Suite, **Burp**, **K2 Security Platform**
suite de testare Web – *e.g.*, SaaS (*Software As A Service*)

instrumentele native pentru dezvoltatori
oferite de navigatoarele Web + extensii specifice

owasp.org/www-community/Vulnerability_Scanning_Tools

de reținut

Securitatea unei aplicații Web:

trebuie să ia în considerație arhitectura, funcționalitatea, codul-sursă și conținutul în ansamblu

de reținut

Securitatea unei aplicații Web:

nu vizează vulnerabilitățile sistemului de operare ori ale programelor auxiliare

de reținut

Vulnerabilitățile unei aplicații Web
nu sunt neapărat „celebre”
și pot fi independente deseori de securitatea
sistemului pe care este exploatat situl

liste ale vulnerabilităților Internet, inclusiv Web:
cve.mitre.org/cve/
www.exploit-db.com
www.hackerone.com/internet-bug-bounty

OWASP Top 10 Most Critical Web Application Security Risks – ediția curentă: 2017

1. Injection
2. Broken Authentication
3. Sensitive Data Exposure
4. XML External Entities (XXE)
5. Broken Access Control
6. Security Misconfiguration
7. Cross-Site Scripting XSS
8. Insecure Deserialization
9. Using Components with Known Vulnerabilities
10. Insufficient Logging & Monitoring

owasp.org/www-project-top-ten/

avansat

RISK	Threat Agents	Attack Vectors: Exploitability	Security Weakness: Prevalence	Security Weakness: Detectability	Impacts: Technical	Impacts: Business	Score
A1:2017-Injection	App Specific	EASY: 3	COMMON: 2	EASY: 3	SEVERE: 3	App Specific	8.0
A2:2017-Authentication	App Specific	EASY: 3	COMMON: 2	AVERAGE: 2	SEVERE: 3	App Specific	7.0
A3:2017-Sens. Data Exposure	App Specific	AVERAGE: 2	WIDESPREAD: 3	AVERAGE: 2	SEVERE: 3	App Specific	7.0
A4:2017-XML External Entities (XXE)	App Specific	AVERAGE: 2	COMMON: 2	EASY: 3	SEVERE: 3	App Specific	7.0
A5:2017-Broken Access Control	App Specific	AVERAGE: 2	COMMON: 2	AVERAGE: 2	SEVERE: 3	App Specific	6.0
A6:2017-Security Misconfiguration	App Specific	EASY: 3	WIDESPREAD: 3	EASY: 3	MODERATE: 2	App Specific	6.0
A7:2017-Cross-Site Scripting (XSS)	App Specific	EASY: 3	WIDESPREAD: 3	EASY: 3	MODERATE: 2	App Specific	6.0
A8:2017-Insecure Deserialization	App Specific	DIFFICULT: 1	COMMON: 2	AVERAGE: 2	SEVERE: 3	App Specific	5.0
A9:2017-Vulnerable Components	App Specific	AVERAGE: 2	WIDESPREAD: 3	AVERAGE: 2	MODERATE: 2	App Specific	4.7
A10:2017-Insufficient Logging&Monitoring	App Specific	AVERAGE: 2	WIDESPREAD: 3	DIFFICULT: 1	MODERATE: 2	App Specific	4.0

factori de risc asociați celor mai importante vulnerabilități

de reținut

Principii de securitate a aplicațiilor Web

separarea funcționalităților

soluții diferite – uzual, găzduite de platforme eterogene – pentru server(e) Web, server(e) de aplicații Web, server(e) de stocare (*i.e.* baze de date), (micro-)servicii, sisteme adiționale etc.

de reținut

Principii de securitate a aplicațiilor Web

limitarea privilegiilor

la nivel de sistem de fișiere,
pentru baze de date,
acordarea de permisiuni/roluri utilizatorilor
sub care rulează diverse componente,...

de reținut

Principii de securitate a aplicațiilor Web

ascundere a secretelor – *e.g.*, parole, SID-uri,…

recurgere la biblioteci standard

actualizate!

menținere + studiere a fișierelor de jurnalizare (*log*-uri)

efectuare de teste și ajustări (*Web tunning*)

avansat

Reguli/bune practici (Sverre Huseby):

Do not underestimate the power of the dark side

Use POST/PUT requests when actions have side effects

In a server-side context,
there is no such thing as client-side security

Always generate a new session ID once the user logs in

Never pass detailed error messages to the client

Identify every possible meta-character to a subsystem

When possible, pass data separate from control information

Reguli/bune practici (Sverre Huseby):

Do not blindly trust the API documentation

Identify all sources of input to the application

When filtering data,
use white-listing rather than black-listing

Create application-level logs

Never use client-side scripts for security

Pass as little internal state information
as possible to the client

Reguli/bune practici (Sverre Huseby):

Don't assume that requests will come in a certain order

Filter all data before including them in a Web page, no matter what the origin

Stick to existing cryptographic algorithms, do not create your own

Never store clear-text passwords

Assume that server-side code is available to attackers

Security is not a product – it is a process

de reținut

Riscurile de securitate nu vizează doar proprietarul sitului/aplicației Web, ci și utilizatorul final

avansat

de reținut

Riscurile de securitate nu vizează doar proprietarul sitului/aplicației Web, ci și utilizatorul final

acțiuni tipice:
spionare a utilizatorului (*user tracking*)
includere de mesaje promoționale (*ad injection malware*)

resurse:
www.w3.org/Security/
security.googleblog.com

de reținut

Disconforturi cauzate de un sit/aplicație nesigur(ă)

financiare – pierdere de bani/informații

de performanță – *e.g.*, blocarea/încetinirea acțiunilor

psihologice – insatisfacție ▸ influență asupra UX

sociale – *e.g.*, incapacitatea de muncă, lipsa comunicării,…

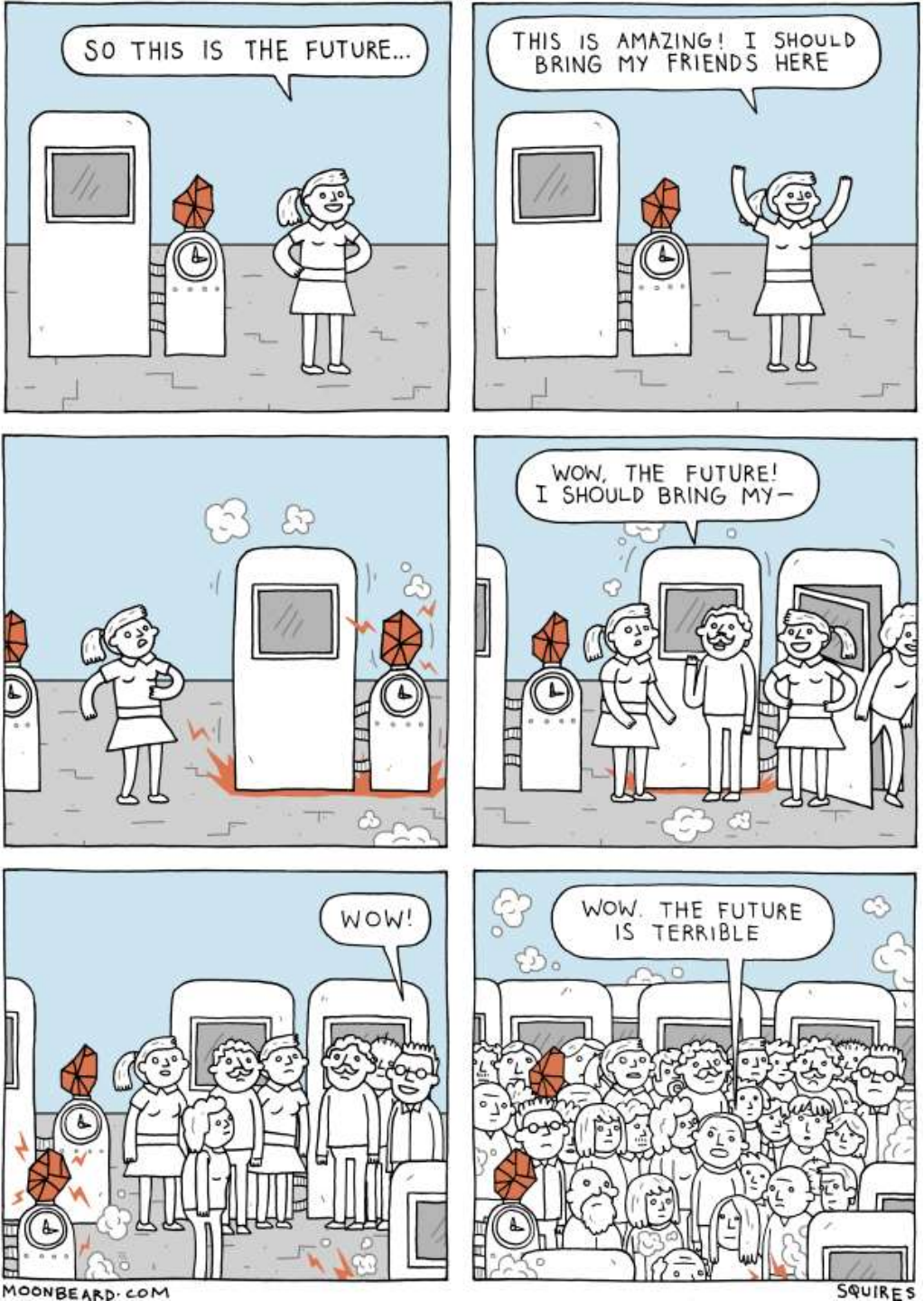
de timp – navigare greoaie, deturnare spre alt URL etc.

rezumat

securitatea aplicațiilor Web

context, tipuri de atacuri, vulnerabilități, prevenire, reguli de bună practică, studii de caz

mulțumiri lui Cosmin Vârlan, PhD


SO THIS IS THE FUTURE...
THIS IS AMAZING! I SHOULD BRING MY FRIENDS HERE
WOW, THE FUTURE! I SHOULD BRING MY—
WOW!
WOW. THE FUTURE IS TERRIBLE
MOONBEARD.COM
SQUIRES

Mult succes!